PROBLEM STATEMENT

Discover.
Read.
Score.
Respond.

02

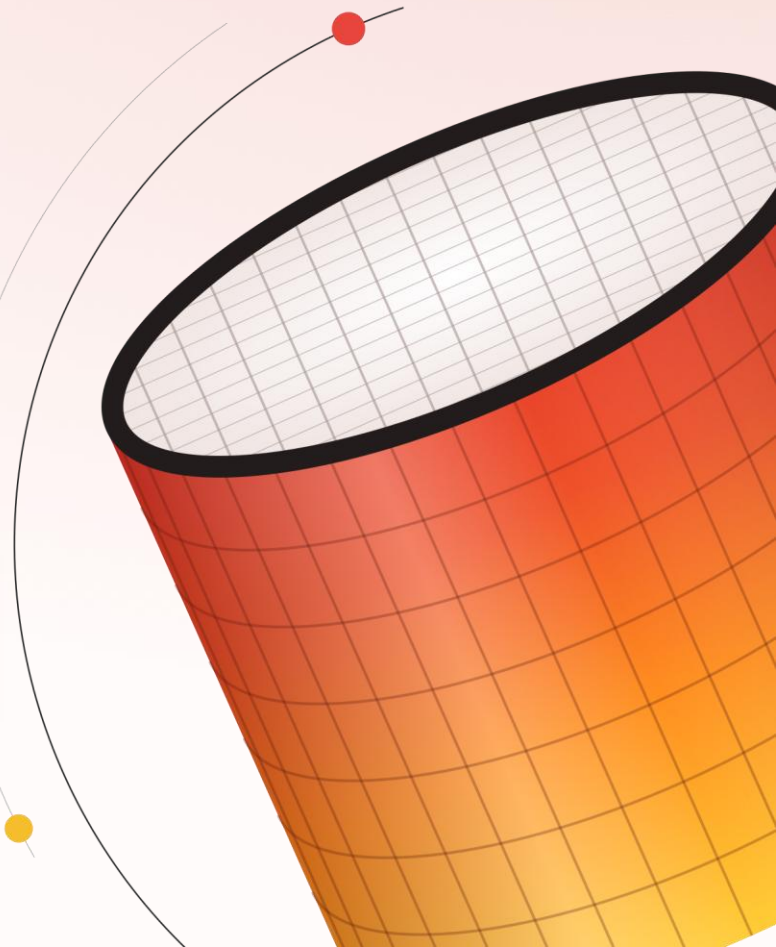
ShadowGuard AI

Governing shadow AI across the university

Finds the AI tools staff actually use, reads each vendor's privacy policy with quoted proof, and asks IT to act before student data leaks.

Answers two of the example use cases

- **HR & IT operations automation** → — Finds tools, files tickets
- **Intelligent document processing** → — Reads and quotes policies



THE PROBLEM

A free AI grader rewrote its privacy policy, and nobody noticed

A lecturer uploads class essays

Exams office staff use GradeSync Pro, a free AI grader, to beat a marking deadline.

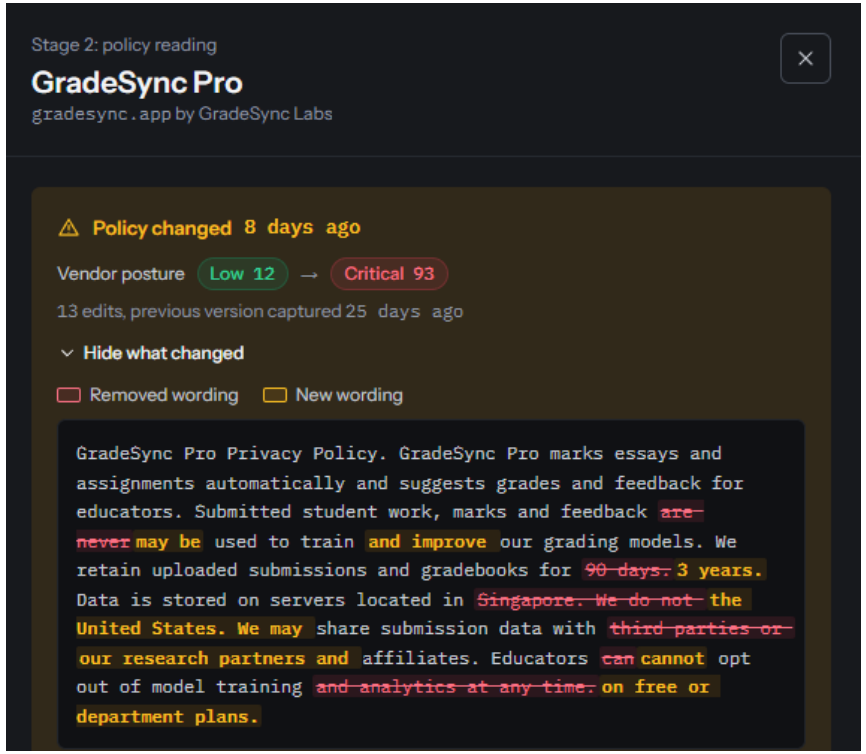
The vendor quietly rewrites its policy

Student work may now train its models, sit in the US for 3 years and go to research partners. No opt-out.

Exposure jumps from Low 12 to Critical 93

Coursework leaves Malaysia: PDPA s. 9 (security) and s. 129 (cross-border transfer) are at stake.

Demo scenario with a fictional vendor. The policy diff on the right is the dashboard's own output.



THE PROBLEM

Staff bring their own AI faster than IT can vet it

78%

of AI users bring their own AI tools to work

75% of knowledge workers already use AI at work

Source: Microsoft and LinkedIn, 2024 Work Trend Index. Survey of 31,000 people in 31 countries.

Why today's approach fails

Manual review doesn't scale

Every vendor policy needs re-reading each week to catch silent rewrites.

Blanket bans backfire

Blocking all AI pushes staff onto personal hotspots that IT can't see.

Not every upload is equal

A public syllabus is fine. Exam scripts in a tool that trains on them are not.

OUR SOLUTION

One pipeline that discovers, reads, scores and responds

01

Collect

Python log shipper and laptop proxy

- Squid, FortiGate & laptop proxy
- Auto-discovers unknown AI hosts
- Staff directory for departments

02

Analyse

FastAPI on Vercel, Neon Postgres

- Safe fetcher + rules & Gemini
- 5 scored factors + 4 advisories
- Quote-checked, 0–100 exposure

03

Act

Next.js 15 rail & graphite UI

- Live map, PDPA checks & brief
- Human-approved block lifecycle
- SHA-256 hash-chained audit log

No TLS decryption, no prompts, no files. Usernames are hashed with a secret salt before anything leaves campus.

LIVE DEMO

Two minutes, end to end, on the live site



What we'll show

1. The Overview on one screen
2. Lock a region pin for deep dive
3. Open vendor: quotes, advisories & PDPA
4. Simulate a burst of new traffic
5. Approve block, export & verify audit

shadowguard-ai-bice.vercel.app

HOW IT WORKS

Find the tools, then read their policies with proof

Proxy or DNS log → Match AI domains → Fetch policy safely → Rules + Gemini → Quote and trap check

01 Discover

- Reads Squid or FortiGate logs, or a laptop proxy's connection lines
- Collectors watch catalogued AI domains; ingest API discovers unknown AI services
- Hashes usernames with a secret salt at the source; no URLs, prompts or staff IPs

02 Read

- Answers five scored questions plus four supplemental compliance advisories
- Every answer must quote a whole sentence from the policy, or it is dropped
- Rules and Gemini read separately; disagreement or hidden instructions mark the vendor Unverified

HOW IT WORKS

Score the exposure, then let a person decide

03 Score

Exposure = posture × sensitivity × usage

Posture 0–100 from the five policy answers

Sensitivity 0.30–1.0 for the data a department holds

Usage 0.6–1.0, rising with distinct users

Low <30 | **Moderate** 30+ | **High** 50+ | **Critical** 70+

04 Respond

High or Critical

An IT risk ticket and a Teams nudge, at most once a day per department and tool

Critical

A block proposal waits for an admin; a rejection keeps it quiet for 7 days

Never automatic

Admins approve blocks, mark applied & checked, and export firewall configs

SECURITY AND COMPLIANCE

Built as a security product first

Every control lives in code, and most have a test that proves it.

SECURITY.md maps each OWASP Top 10 category to the file that implements it and the test that checks it.

Small supply chain

The frontend runs on Next.js, React and server-only. Charts, diff and menus are built in-house.

OWASP Top 10

SHA-256 hash-chained audit log, signed sessions, nonce CSP, SSRF guard & rate limits.

PDPA (Act 709)

Every vendor is checked against sections 8, 9, 10 and 129.

Accessible

Keyboard paths, focus traps and screen-reader announcements throughout.

PERFORMANCE

Fast enough to watch the network live

4 s

Live feed

The map and traffic table update while the tab is open.

8 s

Full summary

Every 8 s while traffic arrives, every minute when quiet.

0.2–0.5 s

Dashboard reads

The app and its database both run in Singapore.

240 / min

Reads per client

Plus 20 writes; failed sign-ins are capped too.

90 days

Raw telemetry kept

Older rows are pruned; the summaries stay.

0

Slow calls in transactions

Teams nudges go out only after the database commits.

DEPLOYMENT AND OPERATIONS

Deployed on Vercel, tested on every push

Browser signed session cookie

↓

Next.js 15 frontend Vercel

↓

FastAPI backend Vercel, private service binding

↓

Neon Postgres Singapore, TLS required

One Vercel project, two services, functions in Singapore (sin1).

Checked on every push

GitHub Actions

86 Frontend tests, design contract included

202 Backend tests, 23 of them on a real Postgres

npm audit and pip-audit on every build

ROADMAP

From one campus to every university

Now

Live on Vercel

- Collectors & AI auto-discovery
- Quote-checked policies + 4 advisories
- Tracked block lifecycle + firewall export
- SHA-256 hash-chained audit & print brief

Next

The next build

- Read-only MCP server for Gemini Enterprise
- Push approved blocks directly to firewall APIs
- SSO with Entra ID / Google (mandatory four-eyes)
- Per-university score weights

Later

Year two

- Coaching in the browser before a sensitive upload
- SIEM and ticketing sync
- Workspaces for many campuses

THANK YOU

Try ShadowGuard live

Questions welcome.

shadowguard-ai-bice.vercel.app
Live demo

github.com/B0mb0cl4t5/shadowguard-ai
Source, tests and documentation

Scan for the demo

